

API Security Risk Analysis Report

Aim: API Security Assessment of a Public Demo API
Target API: JSONPlaceholder(jsonplaceholder.typicode.com)
Reported by: M. Pravallika

Overview:

- APIs help applications exchange data.
- Public APIs may contain security risks.
- API testing helps identify vulnerabilities.
- Security analysis improves system protection.
- This task focused on API risk assessment.

API Endpoints Tested:

- /users – Tested user information access.
- /posts – Analyzed post-related data.
- /comments – Checked comment responses.
- Public API responses were inspected.
- Endpoint accessibility was analyzed.

Authorization Issues:

- Data was accessible to all users.
- No access restrictions were found.
- Anyone can view API responses.
- User role validation was missing.
- Weak authorization may expose data.

Rate Limiting & Validation:

- No request limit was observed.
- Unlimited API calls were possible.
- Input validation was not visible.
- Weak validation may accept bad input.
- Missing controls can increase abuse.

Security Impact:

- Data leakage risk may increase.
- Unauthorized access is possible.
- API misuse can affect systems.
- Weak security affects user trust.
- Security gaps may cause breaches.

Conclusion:

This task provided practical knowledge about API security risks and their impact on systems. By testing different API endpoints, issues such as missing authentication, weak authorization, data exposure, and lack of rate limiting were identified. The analysis highlighted the importance of securing APIs through proper access control, validation, and security measures. Overall, API security testing helps improve protection and reduces potential cybersecurity risks.

Tools used:

- Postman for API testing.
- JSONPlaceholder public API.
- Browser DevTools for inspection.
- PDF tools for documentation.
- GitHub for project upload.

Authentication Analysis:

- No login required to access APIs.
- No API token was used.
- Public endpoints were accessible.
- Weak authentication increases risks.
- Unauthorized access may occur.

Data Exposure Risks:

- User information was publicly visible.
- Email and address details were exposed.
- Open access increases privacy risks.
- Sensitive data may be misused.
- Public APIs require better protection.

Risk Classification:

High Risk:

- No authentication mechanism.
- Public access to sensitive data.

Medium Risk:

- No visible rate limiting.
- Weak input validation.

Low Risk:

- Safe public demo API used.
- No harmful actions performed.

Remediation Steps:

- Implement authentication tokens.
- Add proper access control.
- Enable rate limiting.
- Validate user inputs securely.
- Restrict sensitive information